
智安鉴
智能安全检测与漏洞报告系统
2026 年 10 月

# 目录


01 行业背景与痛点

漏洞报告生成的现实困境与四大核心痛点

02 项目概述与系统架构

本地化Web应用 · B/S三层架构 · 14大功能模块

03 核心功能模块

资产·扫描·报告·评分·AI生成·质检·导出·闭环

04 关键技术与测试验证

AI+RAG+CVSS技术栈 · 7大关键技术 · 全量回归

05 创新特色与总结展望

9大创新点 · 竞品对比 · 应用前景与未来规划


CONTENTS

# 漏洞报告生成高度依赖人工，存在四大核心痛点

在攻防演练、渗透测试与等保测评中，漏洞报告是交付成果的核心载体。扫描工具输出的 JSON/JSONL 结构化数据，距离可直接交付的正式报告仍有较大差距；BurpSuite 等工具模板定制能力有限，难以满足政企公文格式要求。

## 01 等级判定主观

漏洞等级依赖工程师个人经验，缺乏统一、可复核的量化标准，不同人判定结果差异大。

## 02 交付质量不可控

字段缺失、证据不足、整改建议空泛，质量审核完全依赖人工抽检，返工率高。

## 03 大模型幻觉突出

通用大模型直接生成易产生与单位既有整改规范不一致的幻觉，AI产出无法直接落地。

## 04 工具链割裂

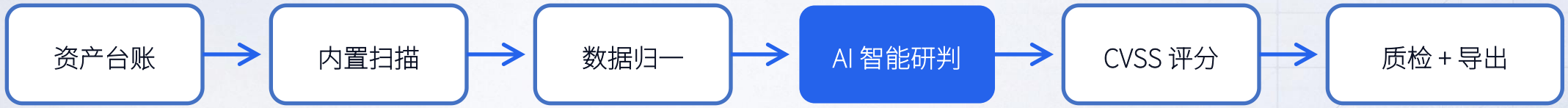
探测、研判、报告、整改四类工具相互独立，数据反复搬运效率低，无法全生命周期跟踪。

核心需求：本地数据安全 · 模板高度可定制 · AI 智能辅助 · 质量可量化 · 扫描—报告一体化闭环

# 构建“扫描—研判—报告—闭”一站式漏洞治理平台

智安鉴以本地化 Web 应用为载体，围绕"资产管理—漏洞治理—智能研判—报告生成"闭环，提供资产台账、漏洞知识库、报告结构化管理、Word/PDF 多模板导出等能力，实施漏洞全生命周期跟踪。

## 核心数据流水线




▼ 导出后进入整改闭环：待整改 → 整改中 → 已修复待复测 → 复测通过（全生命周期跟踪）

**AI + RAG 双驱动**
本地知识库增强，降低大模型幻觉

**CVSS v3.1 量化**
与 FIRST.org 官方一致的评分器

**规则 + AI 质检**
9 维规则引擎 + AI 专家点评

**全本地部署**
数据不出本机，开箱即用

# B/S 三层架构 + AI 子系统，轻量本地部署零外部依赖

### 展示层

原生 HTML5 / CSS3 / JS · fetch + SSE 流式输出 · 响应式界面

### 业务层

Python 3 + Flask 3.1 · Blueprint 模块化
资产 / 域名 / 漏洞 / 报告 / AI / 工具箱 / 扫描器 / 用户管理

### 数据层

SQLite（零外部数据库依赖） · python-docx / reportlab 文档引擎

### AI 子系统四大组件

**① LLM 客户端**
兼容 OpenAI 协议 · 支持流式

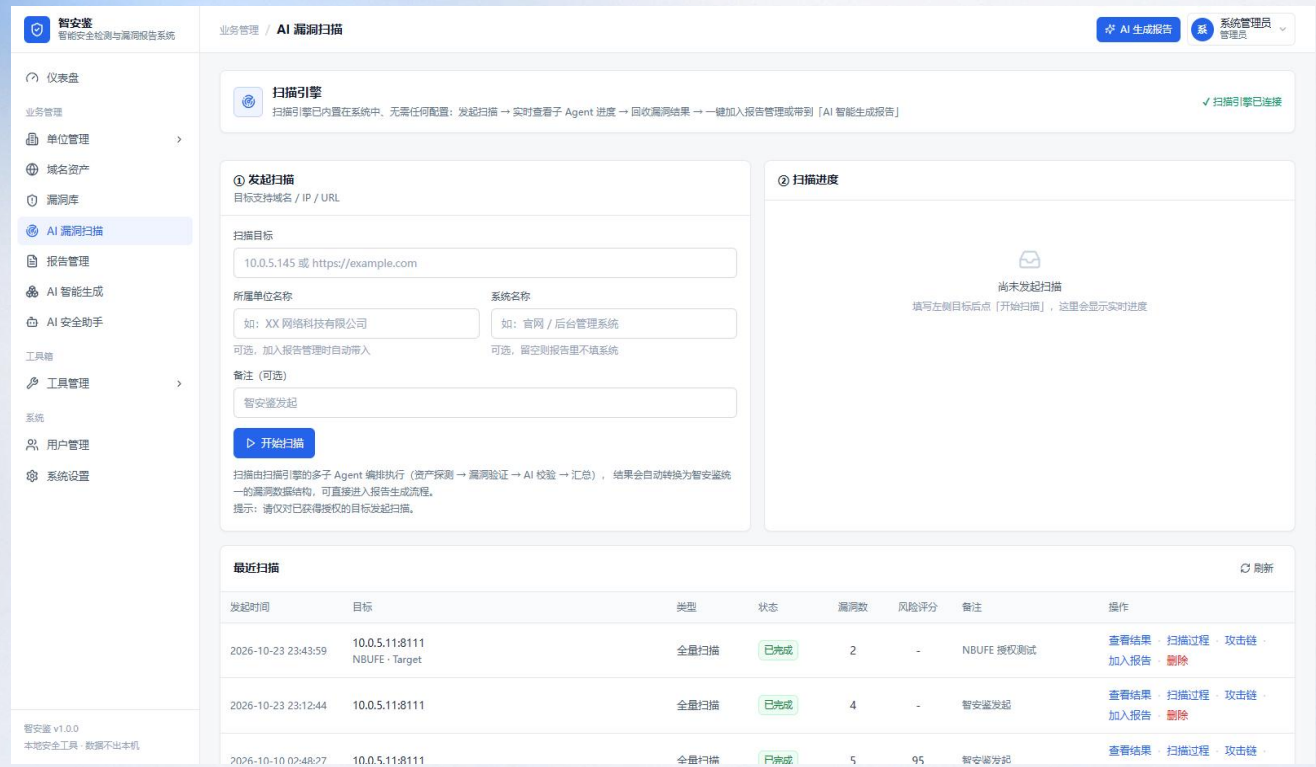
**② 本地 RAG 检索器**
bigram 切分 · 无向量库 · 毫秒级召回

**③ CVSS v3.1 评分器**
严格遵循 FIRST.org 规范 · 精确取整

**④ 报告质量规则引擎**
9 维可解释规则 · 离线可用

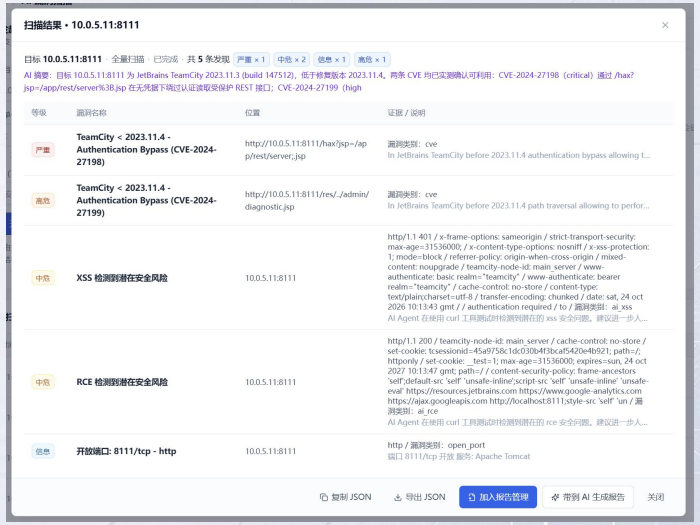
技术栈：Python 3.10 / Flask 3.1 / SQLite / python-docx / docxtpl / reportlab · 普通办公 PC 即可运行

# AI 漏洞扫描模块：全流程跟踪，扫描任务详细记录



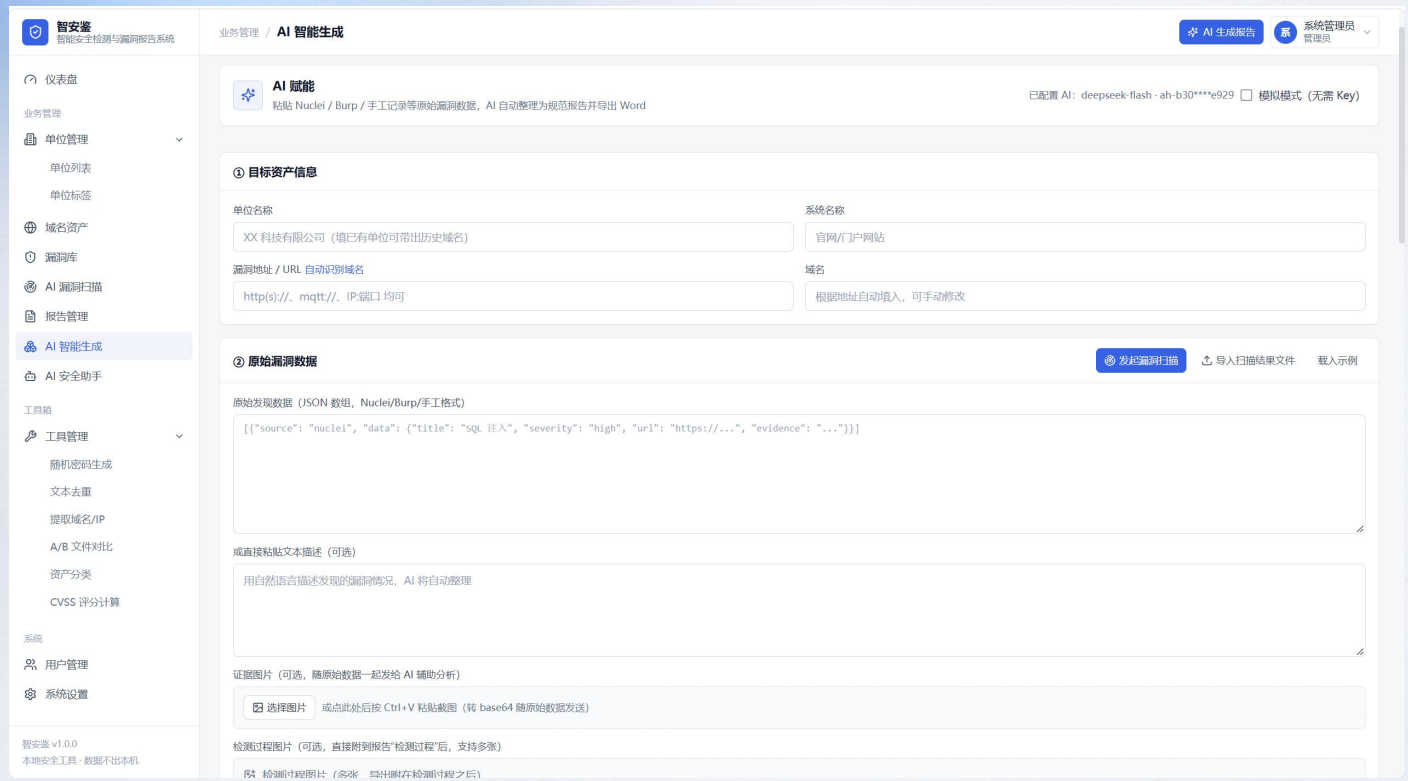

## 内置漏洞扫描引擎

用户输入目标地址后发起任务，系统通过多子Agent编排机制依次执行资产探测、漏洞验证、AI校核与结果汇总，页面实时跟踪扫描进度。




图： AI漏洞扫码模块

# AI 智能引擎：扫描结果一键同步，生成漏洞详细报告




图：AI 智能生成页 — 粘贴 Nuclei / Burp 数据，AI 自动整理为规范报告

- **一键智能生成**
  分析预览 / 润色 / 摘要 / 资产分类
- **本地 RAG 增强**
  回传命中知识条目，约束输出口径
- **修复代码生成**
  根因分析 + 分步修复 + 多语言示例
- **多模板导出与逆向使用**
  支持各类模板形式，新模板可逆向复用

# 各大管理功能模块，覆盖从资产到报告的完整链路

## 01 资产管理模块

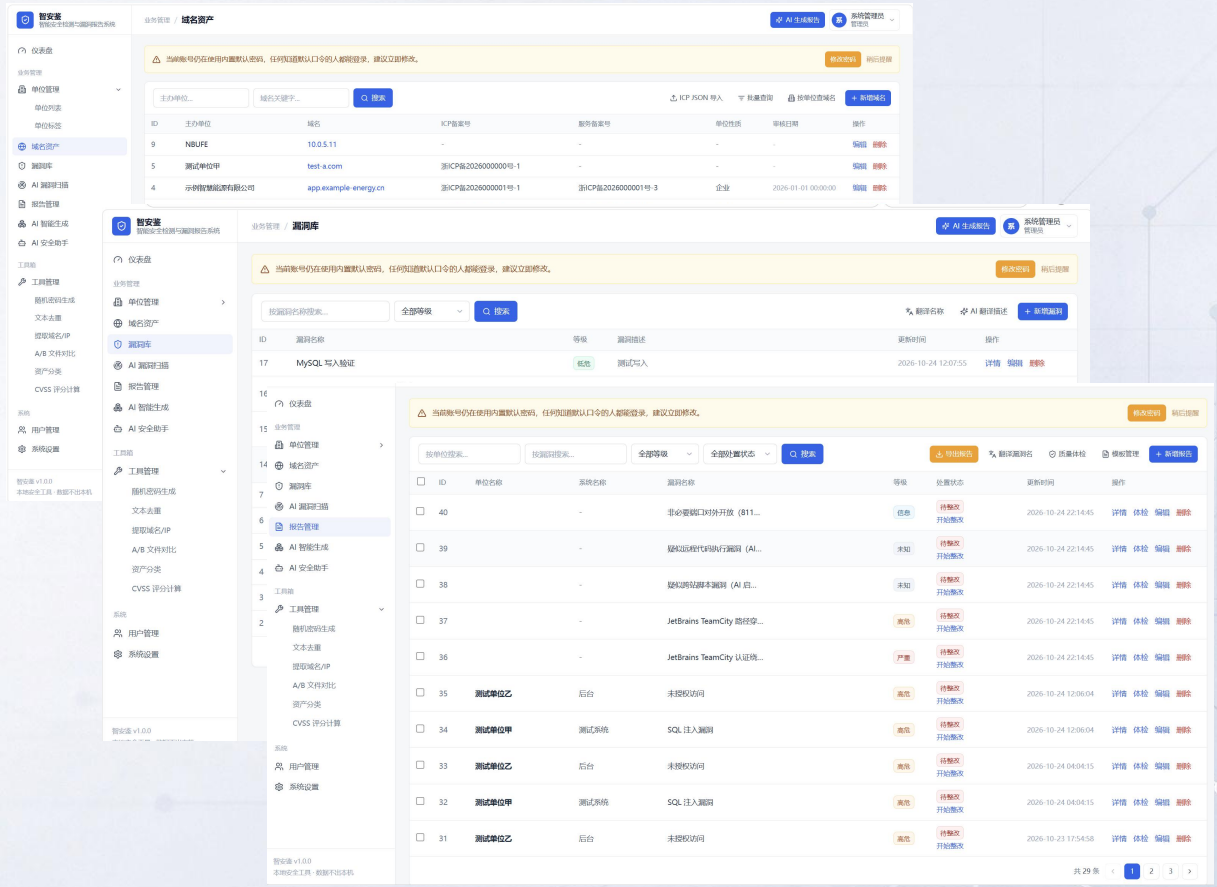
单位/域名双资产台账，文本批量、Excel、ICP多方式导入。

## 02 漏洞知识库

维护漏洞名称/等级/描述/危害/整改建议，RAG检索本地语料。

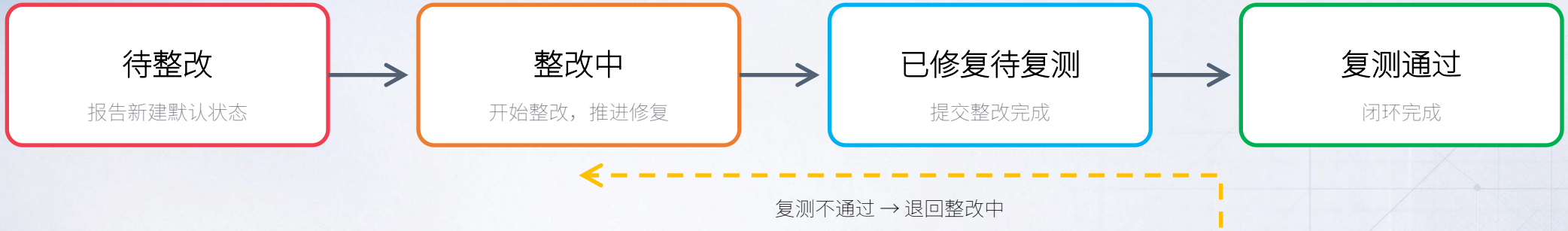
## 03 报告管理模块

全生命周期治理，检测/归属双图多图留证，填地址自动联动资产。
内置四态处置状态机，各类模板协同管理。



# 漏洞处置全生命周期闭环，解决“只通报、不闭环”

## 四态处置状态机




### 整改轨迹留痕

每次流转自动记录时间、动作与备注，形成完整整改轨迹

### 流转合法性校验

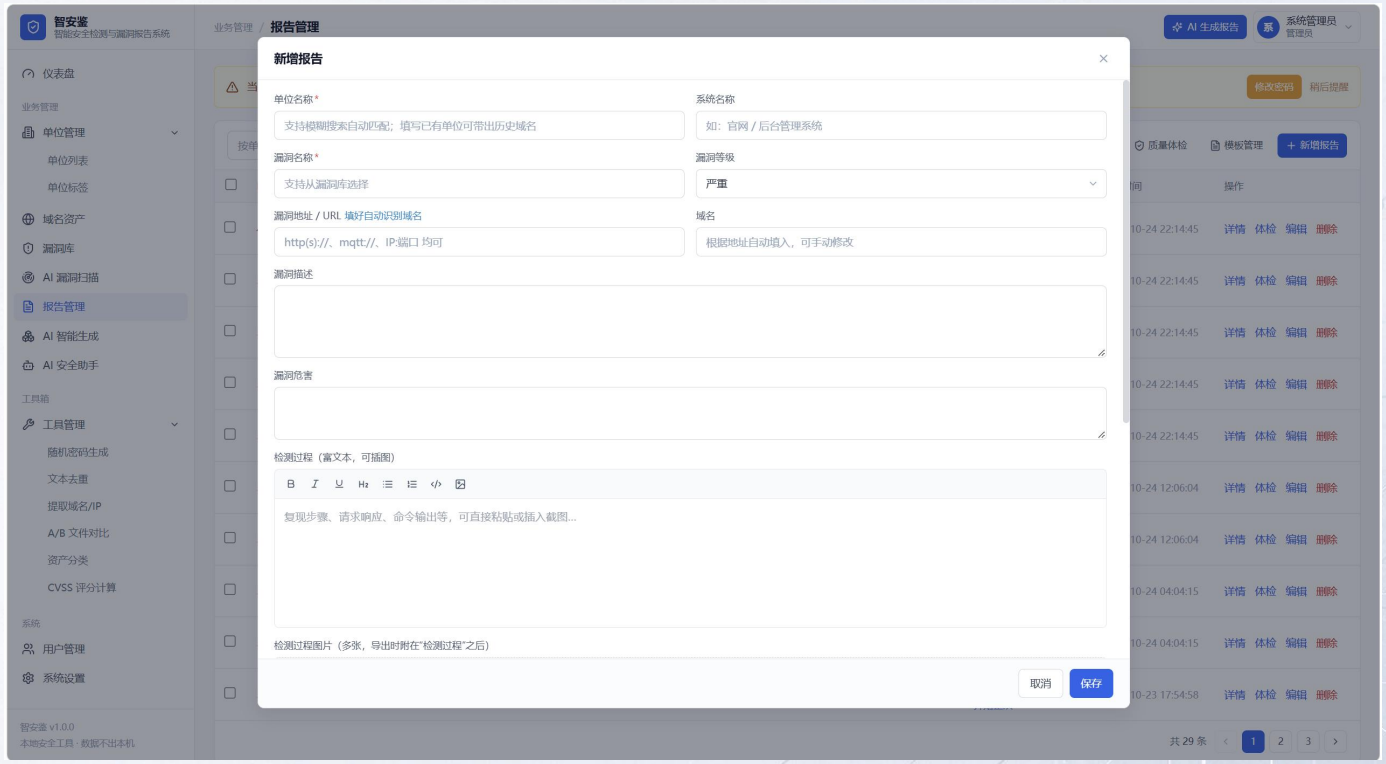
后端拦截跨阶段跳变，杜绝"待整改"直接跳"复测通过"

### 仪表盘闭环统计

四态数量、处置推进率、复测闭环率实时刷新

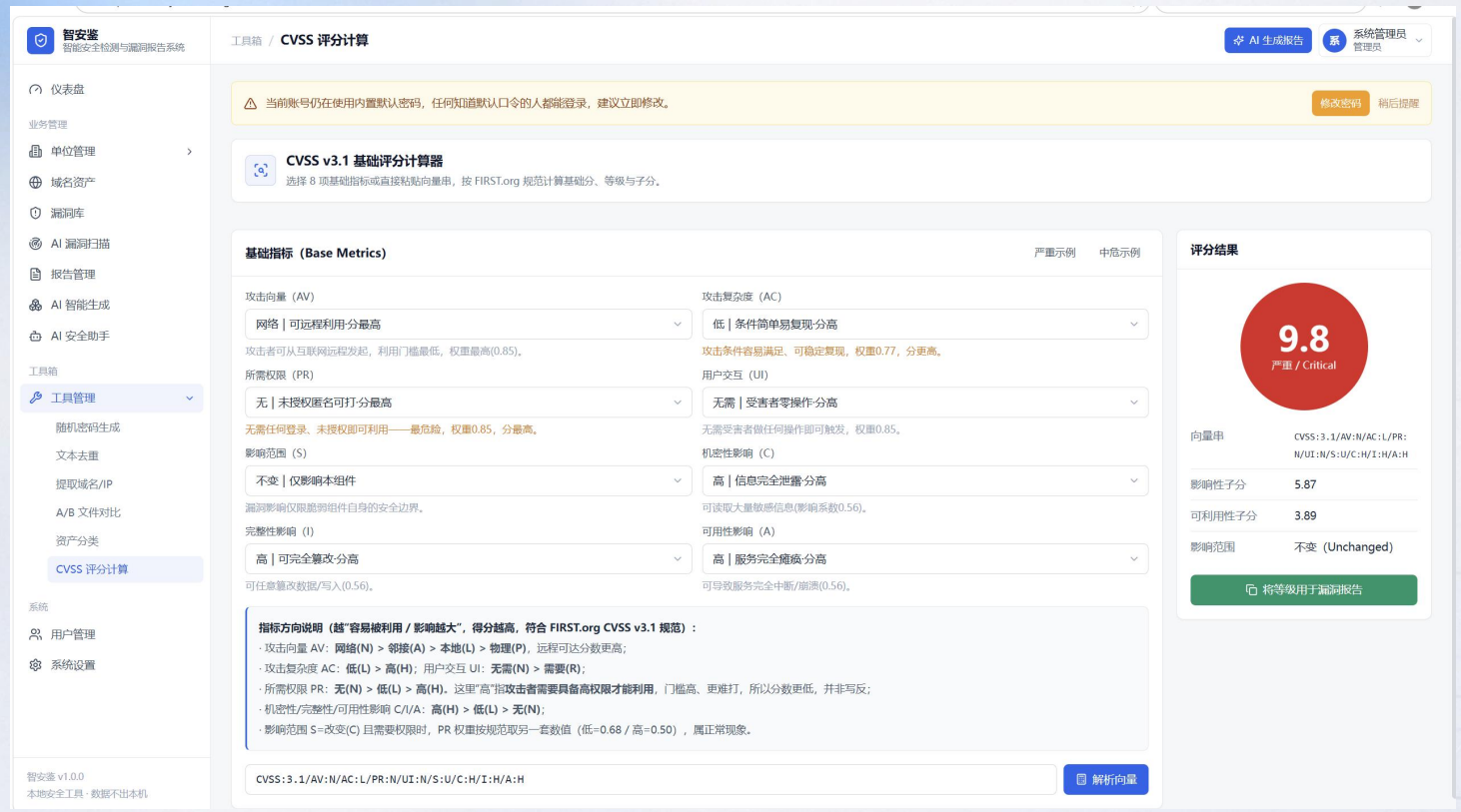
# 手动生成漏洞报告：个性化与规范化需求，模板可逆向复用

- **同步漏洞知识库：**
  漏洞危害等一键填充，信息详情可编辑
- **具体报告内容可修改：**
  满足个性化与规范化需求，不拘泥
- **报告与模板协同管理：**
  与AI生成报告一同管理，方便查看




图：手动生成漏洞报告

# CVSS v3.1 评分模块： 一键映射报告评分等级




严格依据FIRST.org规范实现：

攻击向量（AV）

攻击复杂度（AC）

权限要求（PR）

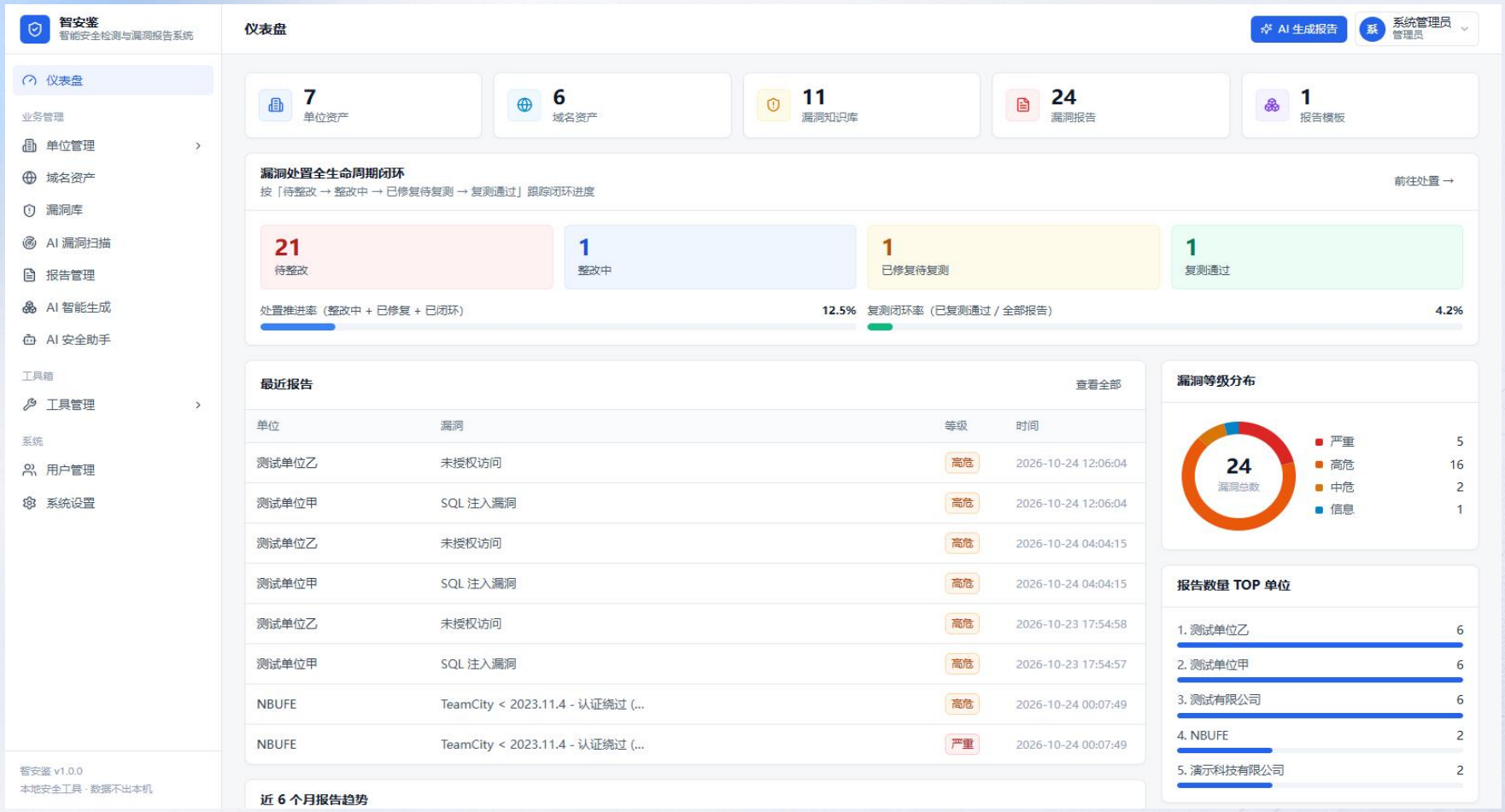
用户交互（UI）

C/I/A影响的基础分计算公式

roundup取整

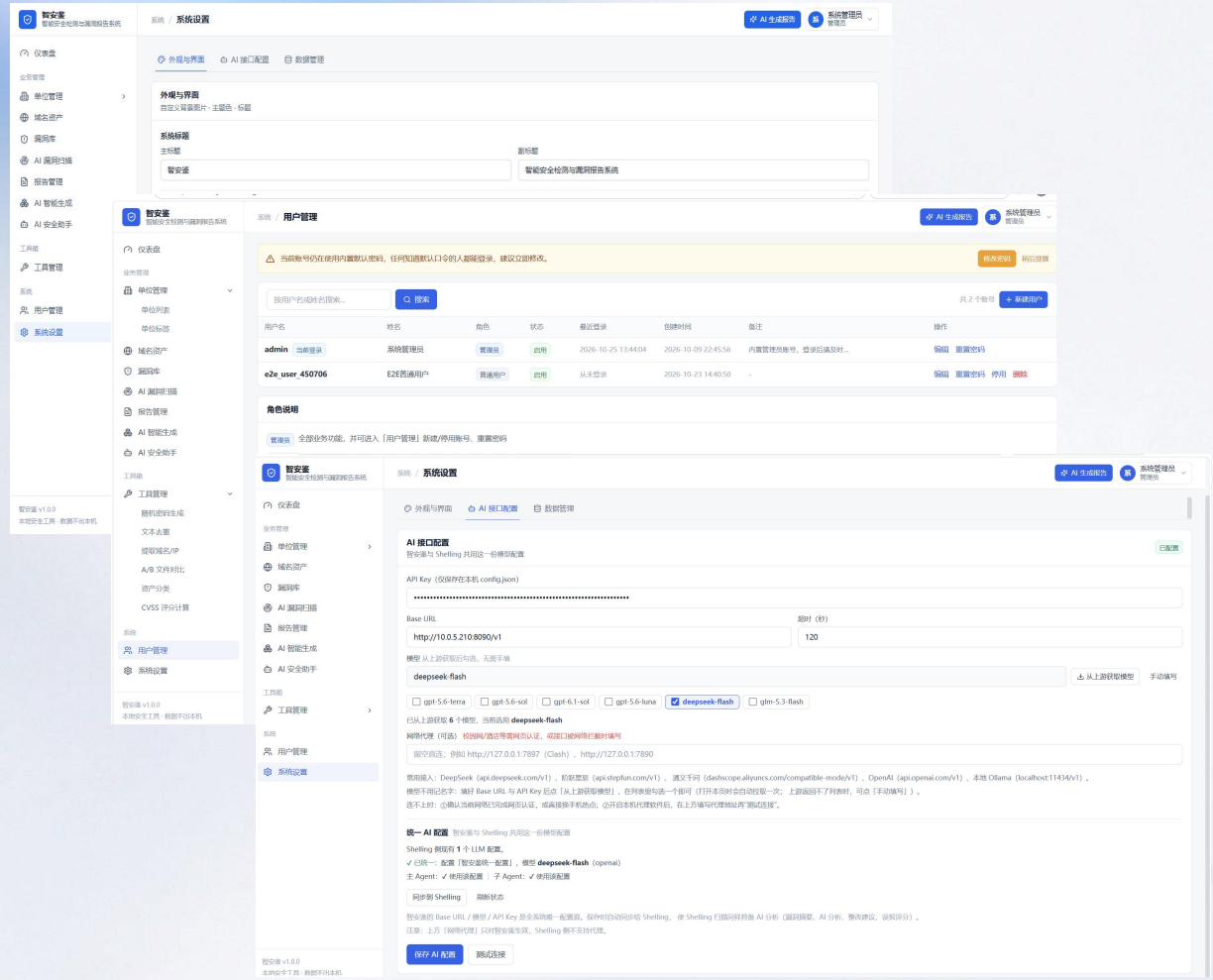
输出分值、严重等级（None/Low/Medium/High/Critical）与向量串

# 仪表盘：报告安全态势全面总览




图：系统仪表盘 — 资产统计 · 漏洞处置全生命周期看板 · 等级分布 · 近6个月趋势 · TOP单位

# 系统设置与AI模型配置：个性化界面设置，各类AI模型配置连接




- **AI模型配置：**
  各类AI模型配置，可测试连接
- **系统界面设置：**
  个性化风格配色，多种类型可自定义
- **用户管理界面：**
  支持团队协作，用户信息管理

# 三大关键技术突破，保证专业性与可靠性

## 01

### 异构扫描结果归一化

格式特征识别 + 递归字段嗅探 + 严重程度词表归一，将 Nuclei、Burp、通用 JSON、纯文本等多源数据映射为统一结构。

**效果：**打通扫描器到正式报告的最后一公里

## 02

### CVSS v3.1 精确计算

完整实现 ISC Base、影响分（Scope 改变/不变两套公式）、可利用性分与 1.08 系数放大，采用规范 roundup 一位小数向上取整。

**验证：**9.8 / 8.5 / 3.5 / 0.0 与 FIRST.org 官方一致

## 03

### 无向量库本地 RAG

对中文漏洞名称与正文做 bigram 切分，以 Jaccard 式重合度加权召回 Top-K 知识，拼入提示词约束模型口径。

**优势：**零外部依赖 · 离线可用 · 毫秒级响应

其他技术亮点：LLM 稳定结构化与思考模型适配 · Word/PDF 双引擎模板渲染 · 系统自身安全防护 · 内置扫描引擎任务调度

# 全量端到端回归测试，功能完整运行稳定

32
Python 模块编译零错误

15+15
页面 + 接口全部正常响应

4
类模板导出全部通过

0
已知阻断性问题

## 典型测试用例验证

**CVSS 准确性：** 标准向量 9.8 / 8.5 / 3.5 / 0.0 与官方计算器完全一致

**处置闭环：** 四态流转正确，非法跳变被后端拦截

**资产联动：** 填地址自动识别域名，保存自动登记资产，幂等去重

**干净环境：** 清空数据与密钥后复跑冒烟用例全部通过

# 各大创新点，形成差异化组合优势

## 01 大模型 + 本地 RAG 双驱动

无外部向量库条件下实现本地知识库相似度召回，注入单位既有整改口径，显著降低大模型幻觉。

## 02 规则兜底 + AI 增强质量体检

9 维可解释规则引擎保证质量底线，再以 AI 专家点评提供高阶建议，首次将交付前质检引入报告生产。

## 03 CVSS v3.1 标准化量化

内置与 FIRST.org 官方一致的评分器，把主观的"高/中/低"经验判断转为可复核的向量与分值。

## 04 成品报告逆向生成模板

上传一份现成漏洞报告 docx，自动解析段落并预猜字段映射，生成专属可复用模板，版式完全一致。

## 05 漏洞处置全生命周期闭环

四态状态机 + 整改轨迹留痕 + 流转合法性校验，把漏洞治理从"发现报告"延伸到"修复验证"。

## 06 扫描—生成一体化流水线

内置漏洞扫描引擎，发起扫描→自动回收→AI解析→报告导出，打破多工具割裂模式，无缝衔接。

# 与同类方案对比，形成差异化组合优势

| 对比维度 | 扫描器自带报告 | 脚本化方案 | 商业安全平台 | 智安鉴 |
| --- | --- | --- | --- | --- |
| 扫描多源解析 | 仅自身格式 | 需自行开发 | 部分支持 | Nuclei/Burp/JSON/文本 |
| CVSS 量化评分 | 部分 | 无 | 部分 | v3.1 精确内置 |
| 报告质量体检 | 无 | 无 | 弱 | 规则 + AI 双引擎 |
| 本地 RAG 知识增强 | 无 | 无 | 部分云端 | 本地知识库 · 零依赖 |
| 模板自定义程度 | 格式固定 | 需编程 | 受限 | 双格式 + 逆向生成 |
| 漏洞处置闭环 | 无 | 无 | 弱 | 四态状态机 + 轨迹 |
| 数据本地化 | 是 | 是 | 多为云端 | 全本地 · 密钥本地 |

**结论：** 智安鉴在多源归一、CVSS量化、质量体检、本地RAG、双格式模板与处置闭环等方面形成差异化组合优势，且保持轻量本地部署与低上手门槛

# 应用前景广阔，持续迭代升级

## 应用场景

- 渗透测试团队报告编制，大幅提升交付效率
- 高校网络安全实训教学与演练
- 政企安全通报、等保测评与攻防演练
- 安全服务团队内部标准化报告生产

## 下一步规划

- 完善多用户权限与报告流转审批机制
- 本地 RAG 升级为漏洞知识图谱，支持反馈学习
- 扩展更多扫描器格式与批量自动复测
- 沉淀行业送检模板，探索模板市场

从 12 模块到 14 模块，从"导入式报告生成"到"扫描—生成一体化"能力升级


感谢聆听
智安鉴 | 智能安全检测与漏洞报告系统
2026 年 10 月